数据分级分类与安全管理规定

瀚宇智能科技股份有限公司

文档编号 HY-SEC-001　　版本 V3.0　　责任部门 信息安全委员会　　密级 秘密

第一章　总则

第一条　制定目的

为规范公司数据的分类分级、全生命周期保护与安全事件处置，防范数据泄露、篡改与滥用风险，保障公司及客户的合法权益，依据《中华人民共和国网络安全法》《中华人民共和国数据安全法》《中华人民共和国个人信息保护法》及有关国家标准，制定本规定。

第二条　适用范围

本规定适用于公司及各分支机构在经营管理、产品研发、客户服务过程中产生、收集、存储、使用、传输、共享和销毁的全部数据，以及承载这些数据的信息系统、终端设备与存储介质。

第三方合作方在为公司提供服务过程中接触公司数据的，应当签署数据保密协议，并按本规定的同等要求履行保护义务。

第三条　基本原则

- 分类分级保护：按数据的重要程度与敏感程度实施差异化保护；
- 最小必要：仅在实现业务目的所必需的范围内收集与使用数据；
- 责任到人：每类数据明确数据 Owner，对数据的完整性与安全性负责；
- 全程可控：数据流转的每个环节均可追溯、可审计、可追责。

【说明】数据安全的成本应当与数据价值匹配。把公开的营销物料按机密级管理，与把客户身份证号按内部级管理，是同一种错误。

第二章　数据分类

第四条　分类维度

按业务属性将公司数据分为五类，分类用于确定管理归口与保护策略，不直接决定密级。同一份文件可能同时包含多个类别的数据。

表 1　数据分类与管理归口

数据类别	范围说明	数据 Owner	典型系统
业务数据	合同、订单、报价、库存、生产与物流记录	各业务部门负责人	ERP、WMS、CRM
客户数据	客户联系人、交易记录、服务工单、反馈与投诉	客户成功部	CRM、工单系统
员工数据	人事档案、考勤、薪酬、绩效、社保公积金	人力资源部	HR 系统、OA
财务数据	总账、应收应付、成本、预算、税务与银行账户	财务部	财务系统、银企直连
研发数据	需求文档、设计文档、源代码、测试数据、算法模型	研发中心	代码仓库、文档平台

第五条　个人信息

涉及自然人的个人信息按敏感程度单独管理。身份证号、银行账号、生物识别信息、行踪轨迹、医疗健康信息属敏感个人信息，处理时须取得单独同意，并采取加密存储与访问留痕措施。

第三章　数据分级

第六条　分级标准

数据按泄露后可能造成的影响程度分为四级：L1 公开、L2 内部、L3 秘密、L4 机密。分级遵循就高不就低原则，同一数据集内包含多个级别时，整体按最高级别保护。

表 2　数据四级分类定义

级别	定义	典型示例	访问授权	留存期限
L1 公开	可对外发布，泄露无影响	官网内容、宣传物料、招聘信息	无限制	按业务需要
L2 内部	仅限内部使用，泄露影响有限	内部制度、会议纪要、项目计划	全体员工	3 年
L3 秘密	泄露造成较大损失或竞争优势下降	客户合同、报价单、供应商底价、员工薪酬	部门负责人审批，限岗限人	5 年
L4 机密	泄露造成重大损失或法律责任	未公开财报、并购方案、核心算法、源代码	总裁或授权人逐次审批	10 年或永久

第七条　定级与变更

数据在产生时由数据 Owner 完成初次定级，并在元数据中标注。业务变化导致级别需要调整的，由数据 Owner 提出申请，L3 报信息安全委员会办公室备案，L4 报信息安全委员会审议。定级结果每年复核一次。

第八条　降级与脱敏

L4 数据经脱敏处理后可用于分析场景，脱敏须保证无法通过关联分析还原到个体。L3 及以

上的数据对外提供时，原则上应降级为脱敏后的 L2 数据；确需提供原始数据的，按第十一条履行外发审批。

第四章　职责分工

第九条　组织与职责

表 3　数据安全职责分工

角色	主要职责
信息安全委员会	审议数据安全战略与制度，裁定重大数据安全事项，每季度听取一次工作汇报
信息安全办公室	制度落地、分级备案、安全检查、事件协调与对外报告
数据 Owner	本领域数据的定级、授权审批、质量与安全负责
信息技术部	技术措施实施，含加密、权限、日志、备份与脱敏工具
法务与合规	数据出境评估、隐私政策与协议审核、监管沟通
全体员工	按规定使用数据，发现风险及时上报

第五章　全生命周期管理

第十条　采集与传输

采集数据应明确目的、范围与保存期限，不得超范围采集。传输 L3 及以上数据须使用加密通道（TLS 1.2 以上或公司 VPN），禁止通过个人邮箱、个人网盘、即时通讯工具传输。

第十一条　存储与加密

L3 数据须加密存储，L4 数据须加密存储并单独划分安全域。密钥由专人管理，与数据分离存放，每半年轮换一次。数据库备份文件视同原数据保护，备份介质须登记编号并存放于受控区域。

第十二条　使用与共享

内部共享遵循最小必要原则，共享 L3 及以上数据须经数据 Owner 审批并记录用途。对外共享须签署数据共享协议，明确使用范围、保存期限与违约责任。

表 4　不同级别的使用与共享要求

场景	L2 内部	L3 秘密	L4 机密
内部查阅	直接访问	申请 + 部门负责人审批	逐次审批 + 水印
内部共享	直接共享	数据 Owner 审批	禁止共享，按需申请
对外提供	部门负责人审批	数据 Owner + 法务审批	原则上禁止
跨境传输	评估后可行	安全评估 + 监管申报	禁止

第十三条　数据出境

向境外提供数据前须开展出境风险评估，评估内容包括数据类别与数量、接收方所在国家或地区的法律环境、接收方的保护能力与合同约束。涉及个人信息出境的，按国家网信部门规定办理安全评估或签订标准合同。

第十四条　销毁

数据超过保存期限或业务终止的，应履行销毁审批后销毁。电子数据须多次覆写或物理销毁介质，纸质文件须碎纸销毁。销毁过程须两人在场并留存记录，记录保存三年。

第六章　个人信息保护

第十五条　告知与同意

收集个人信息前应以显著方式告知处理目的、方式、种类与保存期限，并取得同意。处理敏感个人信息须取得单独同意，不得以捆绑授权的方式获取。

第十六条　权利响应

个人提出查阅、复制、更正、删除其个人信息的请求，由客户成功部或人力资源部在十五个工作日内响应。无法满足的，应说明理由并提供投诉渠道。

第十七条　委托处理

委托第三方处理个人信息的，须通过合同约定处理目的、期限、方式与保护措施，并对受托方进行监督。受托方不得转委托，事件发生后须在二十四小时内通知公司。

第七章　安全事件响应

第十八条　事件分级与报告

数据安全事件按影响范围分为三级。任何员工发现疑似数据泄露、越权访问或账号异常，应在三十分钟内报告信息安全办公室，不得自行处置或隐瞒。

表 5　数据安全事件分级

级别	判定条件	上报时限	对外报告
一级（重大）	L4 数据泄露或影响 10 万人以上个人信息	30 分钟内报委员会	72 小时内报监管并通知个人
二级（较大）	L3 数据泄露或影响 1 万人以上个人信息	2 小时内	评估后 72 小时内报告
三级（一般）	L2 数据泄露或少量个人信息外泄	24 小时内	内部通报，视情况报告

第十九条　处置流程

1. 遏制：立即断开受影响系统或回收权限，防止影响扩大；

2. 取证：保留日志、快照与现场证据，不得在取证前重启或清理系统；

3. 评估：判定泄露数据类型、数量、影响人群与可能后果；

4. 修复：修补漏洞、重置凭据、加强监控；

5. 报告：按上表时限向管理层与监管部门报告；

6. 复盘：事件结案后 10 个工作日内输出复盘报告与改进计划。

第八章　监督检查与责任

第二十条　检查机制

信息安全办公室每季度组织一次数据安全检查，内容包括权限合规性、加密措施有效性、日志完整性与外发审批执行情况。检查结果纳入部门年度考核。

第二十一条　违规责任

违反本规定造成数据泄露的，视情节给予通报批评、扣减绩效、降级直至解除劳动合同；构成违法犯罪的，移送司法机关。部门负责人对本部门违规行为承担管理责任。

第九章　附则

第二十二条　解释与修订

本规定由信息安全委员会负责解释，日常解释工作由信息安全办公室承担。修订须经委员会审议通过后发布。

第二十三条　生效

本规定自二〇二六年三月一日起施行，原《数据分级分类与安全管理规定》（V2.3）同时废止。此前发布的相关通知与本规定不一致的，以本规定为准。

瀚宇智能科技股份有限公司

二〇二六年二月五日

文件修订记录

版本	修订日期	修订内容	修订人
V3.0	2026-02-05	按《数据安全法》重构分级标准，新增数据出境与事件响应时限	赵翔
V2.3	2025-06-18	补充个人信息保护与脱敏要求	赵翔
V2.0	2024-04-22	首次建立四级数据分级体系	孙磊